

Mapeo Detallado GQM de Preguntas a Requisitos Normativos y Pilares GCI

Tabla orientativa que conecta las principales cadenas GQM (objetivo–pregunta–métrica) con requisitos normativos (NIS2, ENS, RGPD, ISO 27001, etc.) y pilares GCI.[web:20][web:35][web:40][web:41]

1. Leyenda

- Pilar GCI: L (Legal), T (Technical), O (Organizational), C (Capacity), Co (Cooperation).
- Normativas: NIS2, ENS, RGPD/LOPD-GDD, ISO 27001, NIST CSF, etc.

2. Tabla de mapeo

Goal (GCI-Pilar)	Pregunta GQM (resumen)	Métrica principal (ejemplo)	Pilar GCI	Marcos normativos clave
G1.1 Legal cumplimiento	¿Inventario actualizado de normativas aplicables?	M1.1.1 Existencia y madurez de inventario normativo	L	NIS2 (gestión de riesgos y gobernanza); ENS; ISO 27001 A.5
G1.1 Legal cumplimiento	¿Se realizan análisis de brecha de cumplimiento?	M1.1.2 N° de gap analysis en 24 meses	L/O	NIS2; ENS; ISO 27001 (ciclo PDCA, auditorías internas)
G1.1 Legal cumplimiento	¿Contratos críticos con cláusulas de ciberseguridad adecuadas?	M1.1.3 % contratos críticos con cláusulas estándar	L/Co	NIS2 (supply chain); ENS; ISO 27036
G1.1 Legal cumplimiento	¿Procedimientos de evidencia digital?	M1.1.4 Existencia y pruebas de procedimientos de evidencia	L/T	Budapest; NIS2 respuesta a incidentes; GCI Legal
G2.1 Técnico activos	¿Sabemos qué activos tenemos y cuáles son críticos?	M2.1.1 % activos críticos inventariados	T	NIST CSF ID.AM; ISO 27001 A.5; ENS
G2.1 Técnico monitorización	¿Disponemos de monitorización adecuada?	M2.1.2 % activos críticos cubiertos por monitorización 24x7	T	NIS2; NIST CSF DE; ISO 27001 A.8
G2.1 Técnico respuesta	¿Detectamos y respondemos en tiempos razonables?	M2.1.3 MTTD; M2.1.4 MTTR	T/O	NIS2; NIST CSF DE/RS; buenas prácticas SOC
G2.1 Técnico backup	¿Probamos restauraciones de backups críticas?	M2.1.5 N° pruebas restauración y % éxito	T/O	NIST CSF PR.DS, RS; ISO 27001 A.8; ENS
G3.1 Gob. estrategia	¿Existe estrategia de ciberseguridad alineada con negocio?	M3.1.1 Nivel de formalización de la estrategia	O	NIS2 (gobernanza); ENS; NIST CSF Governance
G3.1 Gob. consejo	¿Participa el consejo en supervisión de ciberseguridad?	M3.1.2 N° sesiones de consejo con reporte de ciber/año	O	NIS2 responsabilidad directiva; GCI Organizational

G3.1 Riesgo y continuidad	¿Integramos ciber en gestión de riesgos y continuidad?	M3.1.3 Nº ejercicios de crisis con componente ciber/año	O	NIS2; ISO 22301; NIST CSF RS/RC; ENS
G3.1 Riesgo y continuidad	¿Procesos críticos cubiertos por BCP/DRP con escenario ciber?	M3.1.4 % procesos críticos con BCP/DRP ciber	O	NIS2; ISO 22301; ENS
G4.1 Capacidades formación	¿Formación de empleados en ciberseguridad?	M4.1.1 % empleados con formación anual	C	NIS2 concienciación; ISO 27001 A.6; ENISA campañas. [web:35]
G4.1 Capacidades equipo	¿Equipo de ciberseguridad dimensionado y cualificado?	M4.1.2 Nº profesionales ciber / 1000 empleados	C	GCI Capacity; recomendaciones de talento en ciberseguridad. [web:41]
G4.1 Capacidades equipo	¿Plan de carrera y certificaciones?	M4.1.3 Nº certificaciones / miembro; M4.1.4 rotación	C	GCI Capacity; frameworks de competencias. [web:35]
G5.1 Cooperación externa	¿Participación en foros y redes sectoriales?	M5.1.1 Nº redes/foros activos	Co	GCI Cooperation; NIS2 cooperación; redes CSIRT UE
G5.1 Cooperación reporte	¿Compartimos información de incidentes y amenazas?	M5.1.2 Nº notificaciones a CSIRT/autoridades/redes	Co	NIS2 obligación de notificación; GCI Cooperation
G5.1 Cooperación ejercicios	¿Realizamos ejercicios conjuntos con terceros?	M5.1.3 Nº ejercicios conjuntos / año	Co/O	ENISA ejercicios Cyber Europe; GCI Cooperation

Este mapeo facilita que cada dato recogido en la encuesta empresarial pueda alinearse con:

- Un pilar concreto del GCI.
- Un conjunto de obligaciones o buenas prácticas normativas.
- Un bloque de objetivos nacionales, por ejemplo, en el marco de España Digital 2026.[web:39]